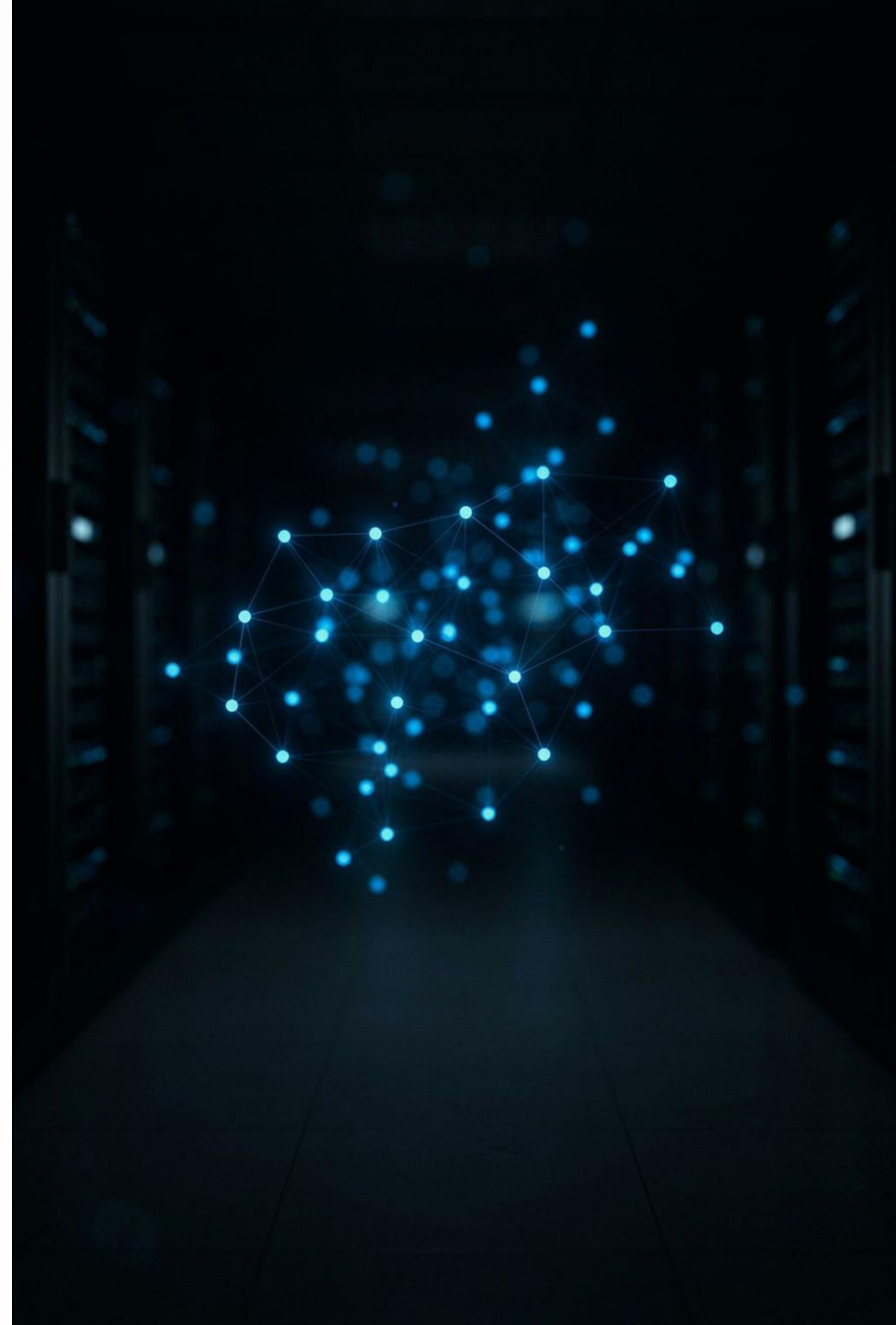


Машинное обучение. Безопасность ИИ-систем

От математических основ нейронных сетей до систематической карты угроз на каждом этапе жизненного цикла ML-модели.



Безопасность ИИ-систем — не надстройка над классическим ML, а измерение, пронизывающее весь жизненный цикл модели: от сбора данных до production



Формат: 14 лекций + 14 лабораторных работ + финальный проект

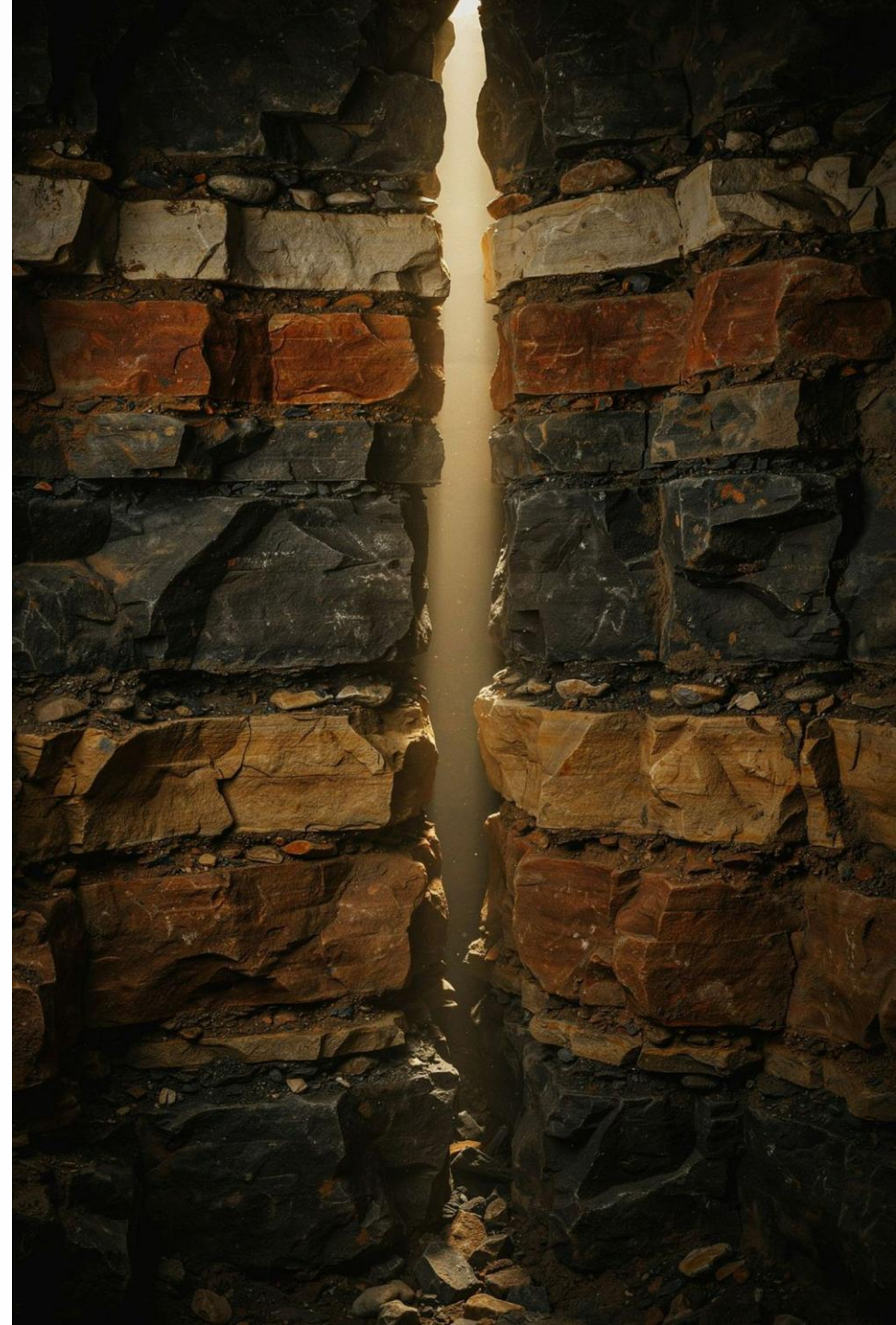
Пререквизиты: линейная алгебра, теория вероятностей, основы Python, базовое понимание машинного обучения

Финальный проект выполняется в формате «Red Team / Blue Team»:

- Каждая команда выбирает целевую модель и датасет (изображение, текст или временной ряд).
- **Red Team этап:** реализовать минимум 2 типа атак разных категорий (например, evasion + poisoning, или digital + physical) и оценить их успешность и трансформируемость.
- **Blue Team этап:** разработать и внедрить защитный механизм (adversarial training, детектор, сертифицированная защита) и количественно оценить снижение эффективности атак.
- **Отчёт:** технический документ (аналог security assessment report) с описанием угроз по модели NIST-таксономии, метриками до/после защиты, рекомендациями по усилению системы.
- **Защита проекта:** презентация с демонстрацией атаки в реальном времени (можно на видео) и обоснованием выбранной защиты.

Безопасность ИИ как сквозное измерение

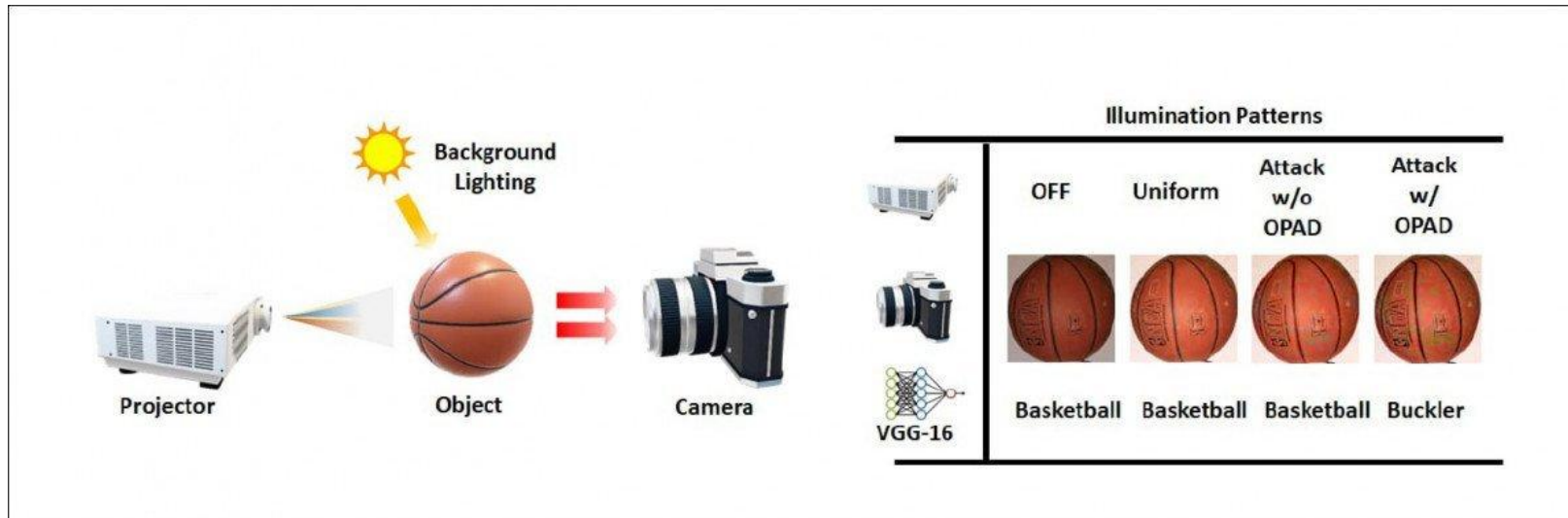
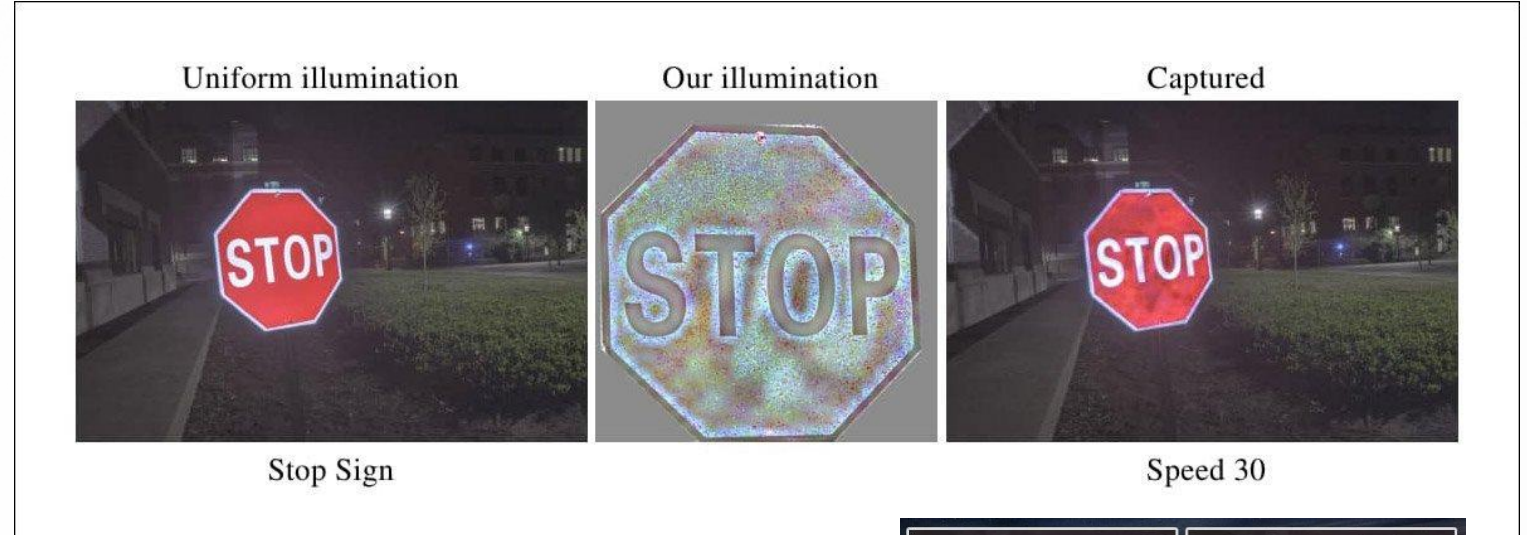
Лекция 1



Почему это важно: реальные последствия атак

Автономные системы

Adversarial examples на дорожных знаках могут обмануть системы компьютерного зрения в автомобилях.

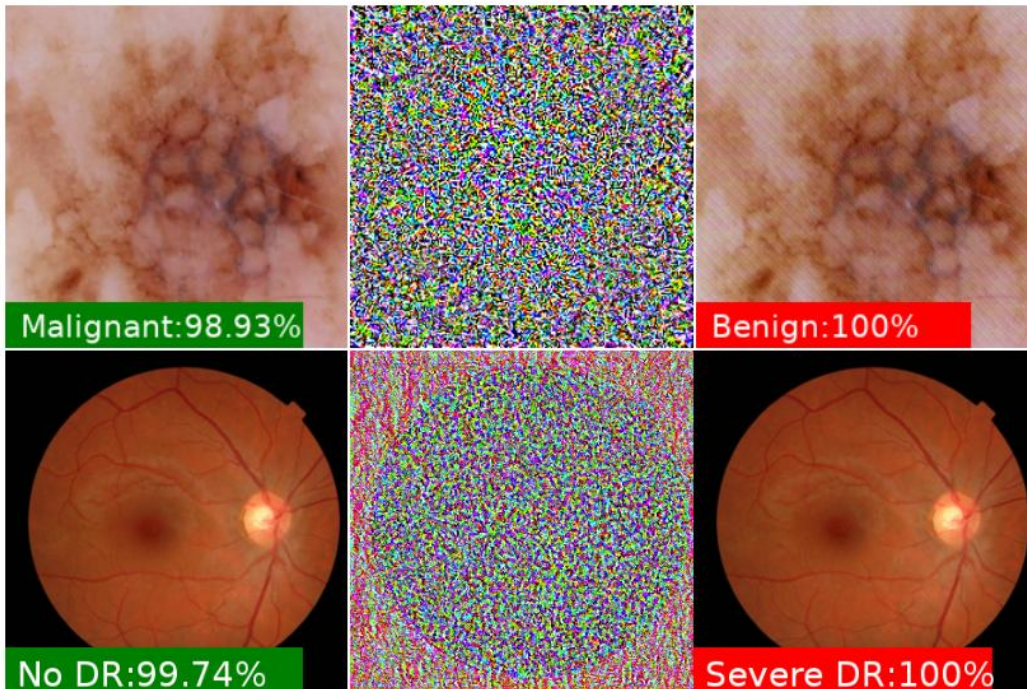


Почему это важно: реальные последствия атак

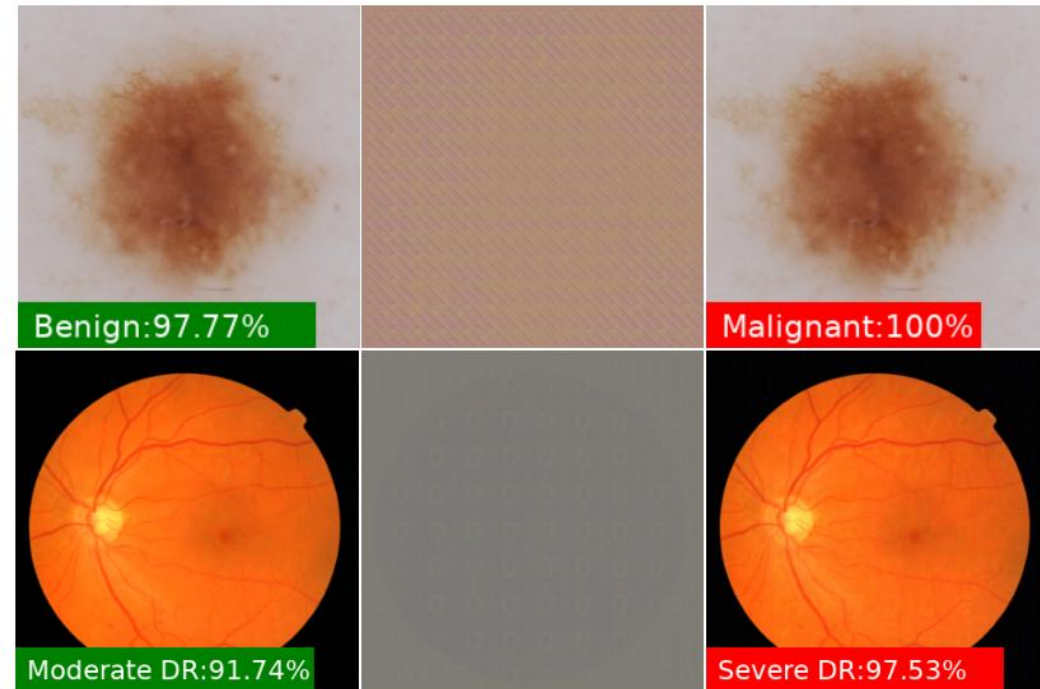
<https://arxiv.org/html/2103.03438v1>

Медицинская диагностика

Backdoor-атаки на диагностические модели могут привести к систематически неверным диагнозам.



(a) Projected Gradient Descent



(b) Generative Adversarial Perturbations

Почему это важно: реальные последствия атак

Финансовые системы

Model extraction позволяет конкурентам воспроизвести проприетарные торговые алгоритмы.

Efficient and Effective Model Extraction

<https://arxiv.org/pdf/2409.14122>



Target: Extract the functionality approximate surrogate from victim with least Monetary cost

Victim API(the oracle): prosperity model trained from scratch on CIFAR-10, accuracy: 94.97%

VS

Traditional DFME

Step 1: query preparation

Train a deep generative model to synthesize queries

Step 2: surrogate training

Direct training with standard Empirical Risk Minimization

Step 3: surrogate deployment

Directly deploy obtained surrogate model for profit

Final results

Query Budget: 20M
Time: 2002.82s
Accuracy: 40.61%

Our E^3

Step 1: query preparation

Select informative and diverse queries with language guidance from publicly available OOD sets

Step 2: surrogate training

Two stage training with varying resolutions along with blackbox temperature scaling

Step 3: surrogate deployment

Distribution alignment with test time target distribution samples

Final results

Query Budget: 0.1M
Time: 398.72s
Accuracy: 94.37%

Conclusion: E^3 achieve much better generalization with only 0.005× the query budget and less than 0.2× the runtime

Универсальная теорема аппроксимации: значение для безопасности

Мощность MLP

Сеть с одним скрытым слоем может аппроксимировать любую непрерывную функцию — это делает её универсальным инструментом.

Обратная сторона

Та же гибкость, которая делает нейросети мощными, создаёт сложные, высокоразмерные решающие границы с многочисленными уязвимыми точками для adversarial атак.



Градиент как инструмент и как уязвимость

Градиентный спуск — основа обучения нейросетей. Но тот же градиент, который оптимизирует веса при обучении, используется атакующим в white-box сценарии для построения adversarial examples: возмущение входа вычисляется как шаг **в направлении градиента функции потерь по входным данным**.



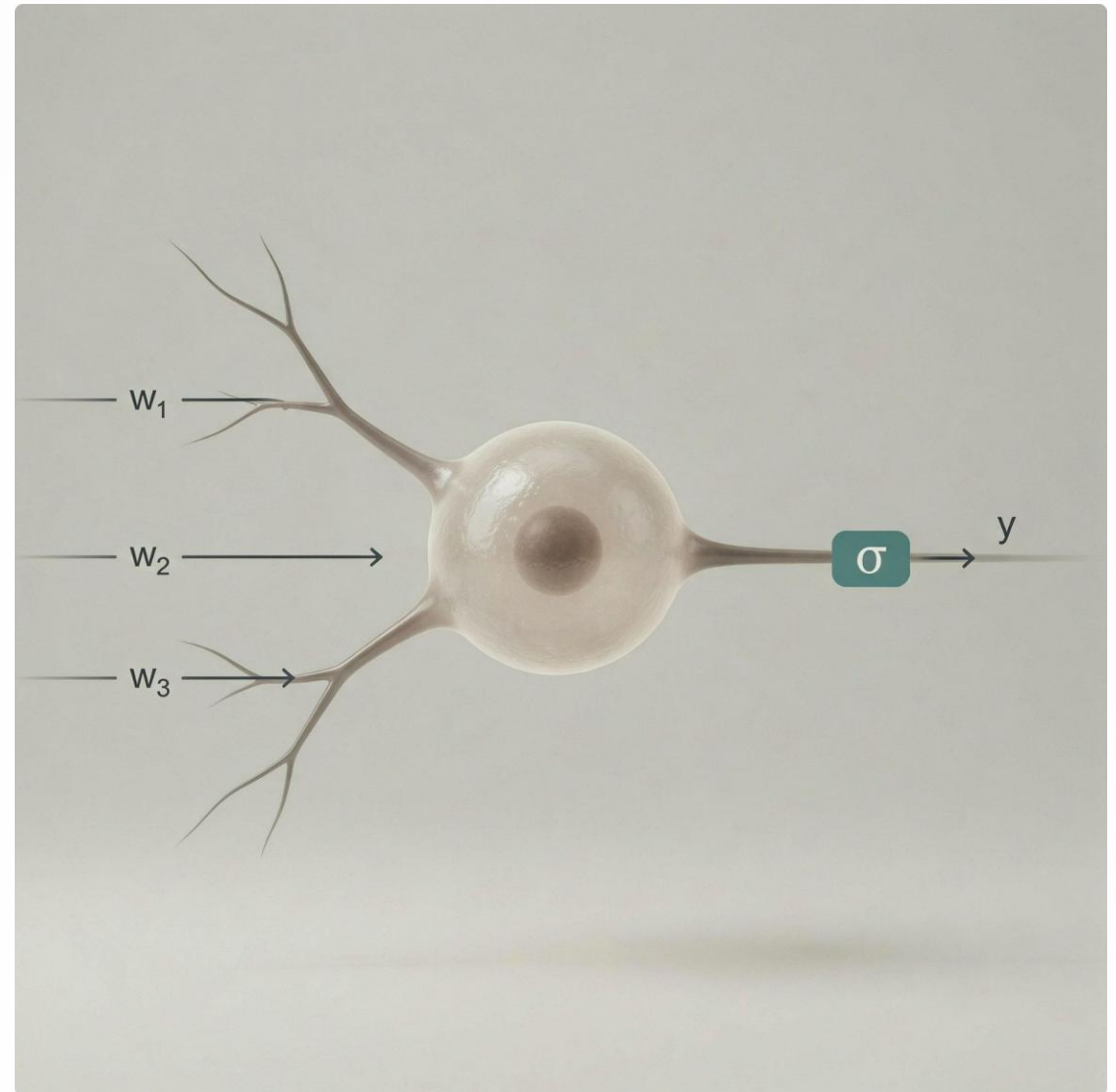
От перцептрона Розенблатта к
многослойным сетям

Перцептрон Розенблатта (1958)

Исторически первая обучаемая модель искусственного нейрона, реализующая линейное разделение классов:

$$y = \sigma(w^T x + b)$$

где σ — функция активации (в исходной версии — пороговая). Веса w и смещение b настраиваются итеративно по правилу коррекции ошибки: если объект классифицирован неверно, вектор весов сдвигается в сторону уменьшения ошибки.



Ограничение: теорема о неразрешимости XOR

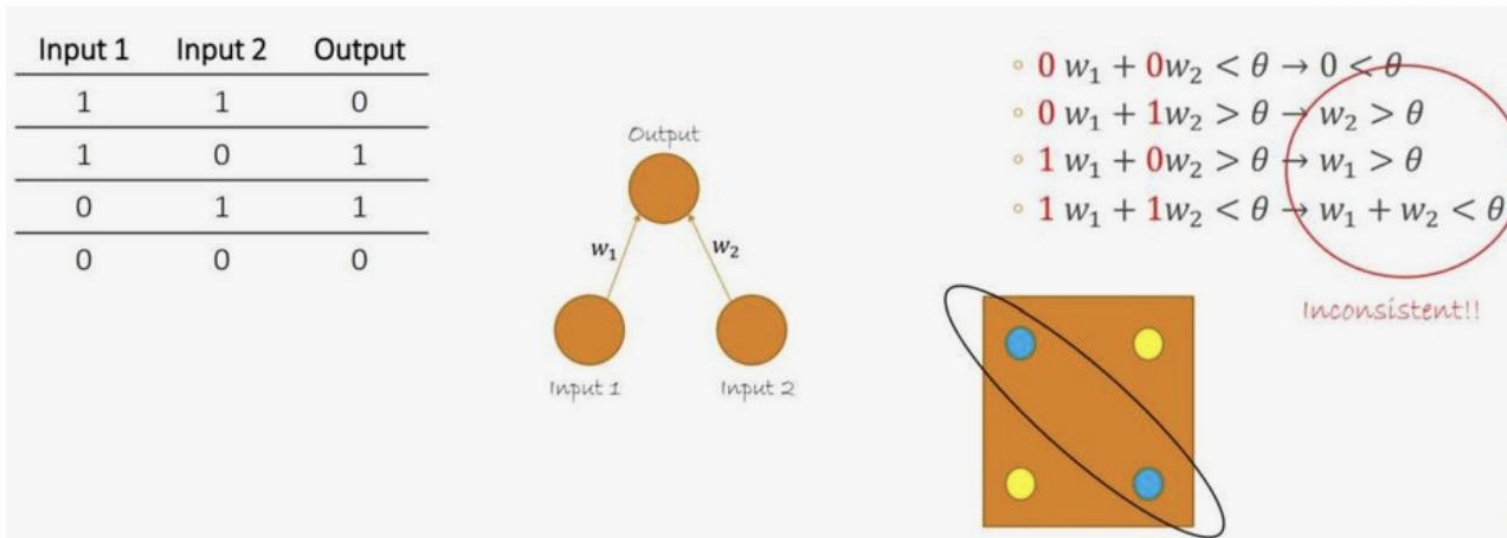
Однослойный перцептрон строит только **линейную гиперплоскость** в пространстве признаков. Он не может разделить классы, не являющиеся линейно разделимыми.

Пример: XOR

Точки (0,0) и (1,1) — один класс; (0,1) и (1,0) — другой. Никакая прямая не разделяет эти множества корректно.

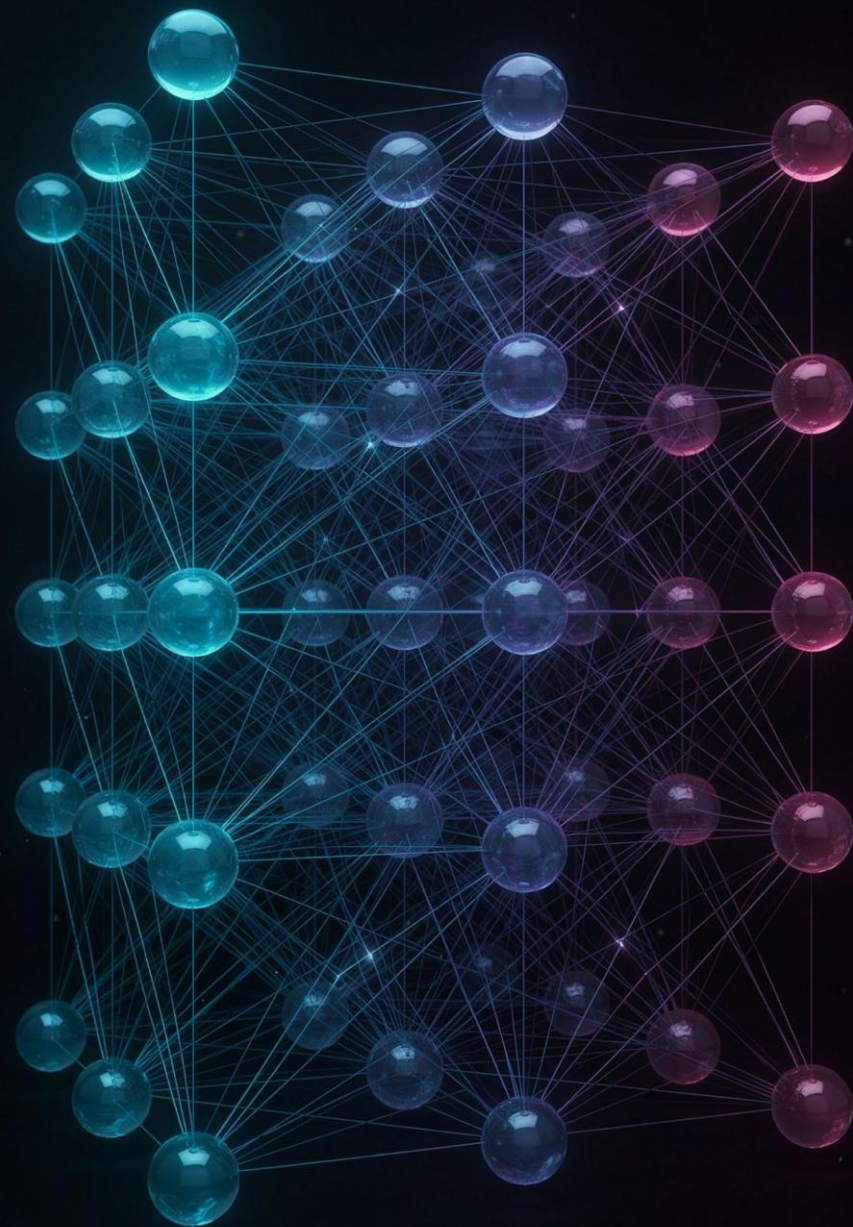
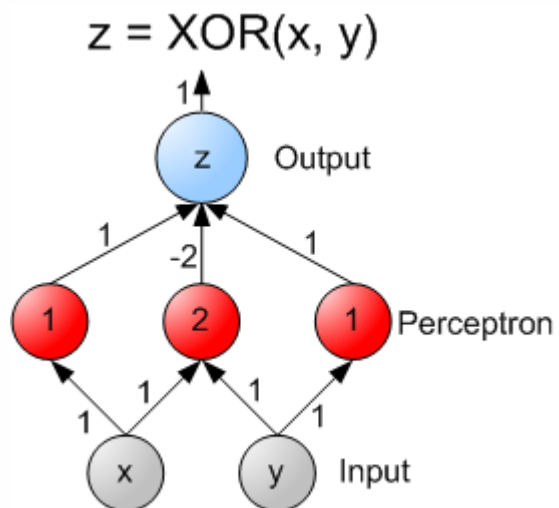
Следствие: «Первая зима ИИ»

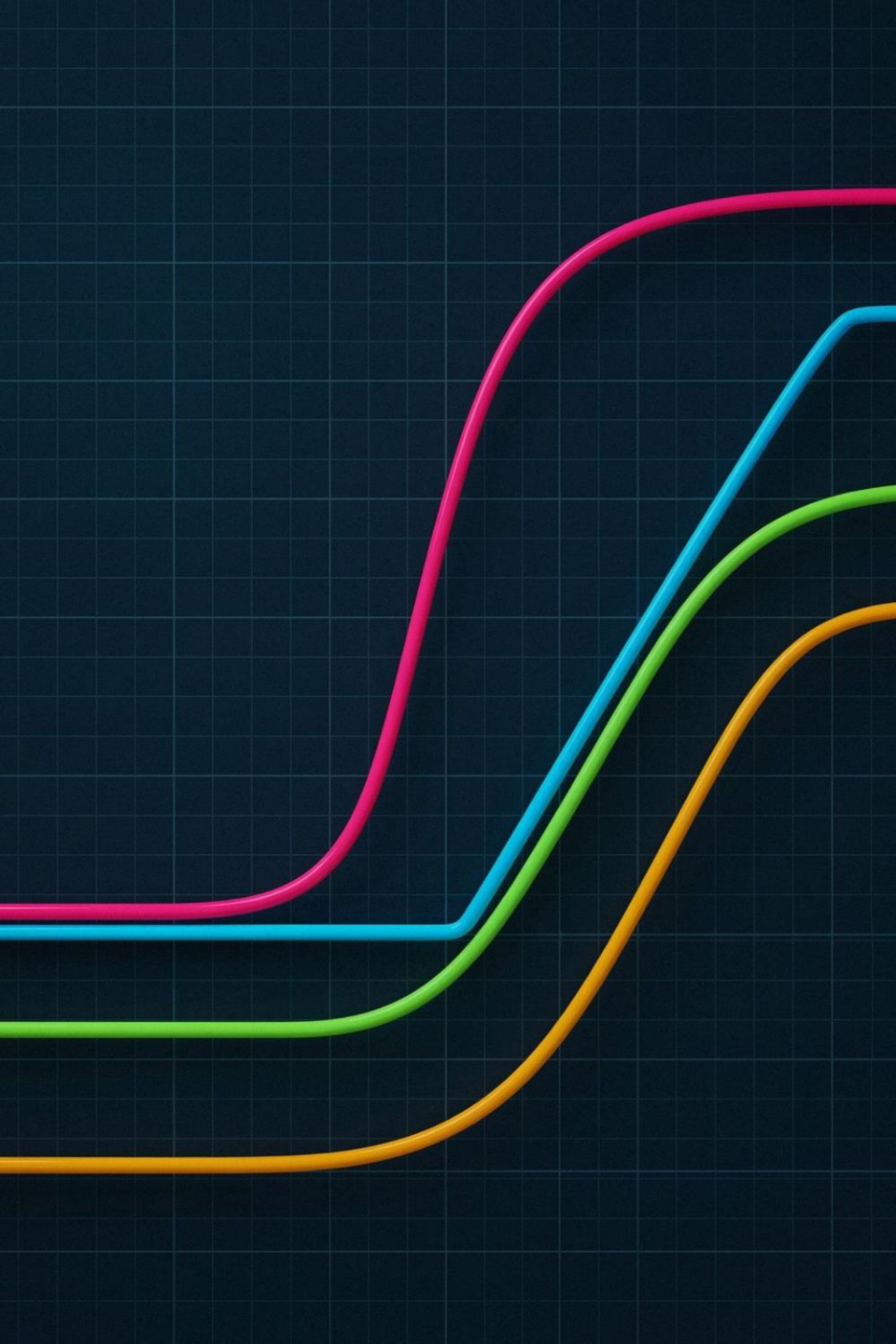
Ограничение, формально доказанное Минским и Пейпертом, на десятилетия затормозило развитие нейросетевых моделей.



Решение: скрытые слои и нелинейность

Многослойная сеть (MLP) с хотя бы одним скрытым слоем и нелинейной функцией активации способна аппроксимировать любую непрерывную функцию с произвольной точностью — **универсальная теорема аппроксимации**. Скрытый слой «перекраивает» геометрию задачи, делая классы линейно separable для выходного слоя.





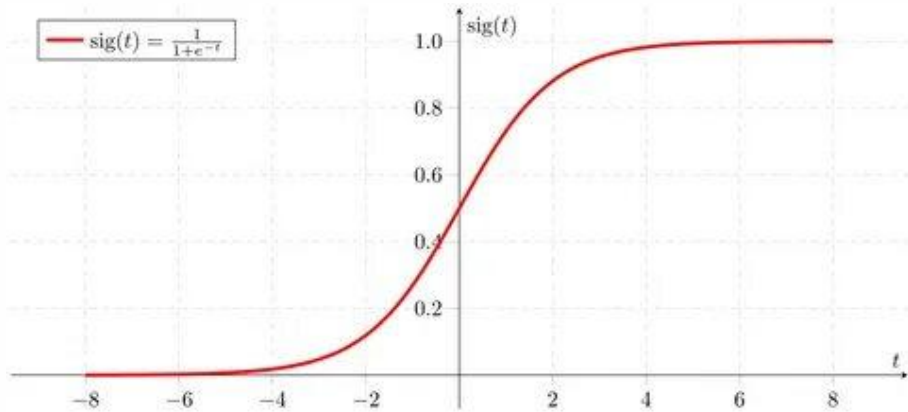
Функции активации и
нелинейная решающая граница

Сигмоида и гиперболический тангенс

Сигмоида

$$\sigma(z) = \frac{1}{1 + e^{-z}}$$

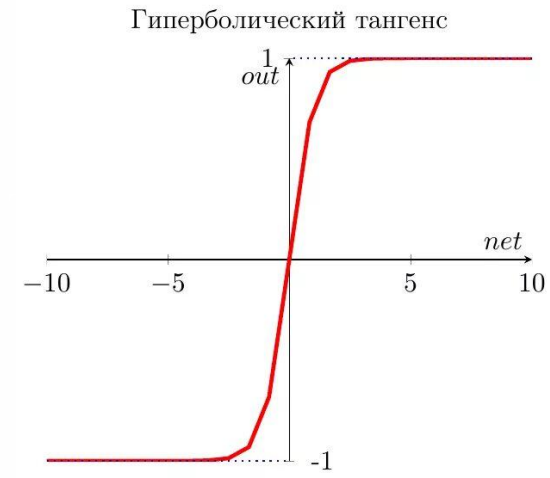
Гладкая, ограниченная в диапазоне (0,1). Исторически первая массово используемая нелинейность. **Проблема:** затухающий градиент при насыщении на краях диапазона.



Гиперболический тангенс

$$\tanh(z)$$

Центрированная относительно нуля версия сигмоиды (диапазон -1..1). Даёт более сбалансированные градиенты, но сохраняет проблему насыщения.

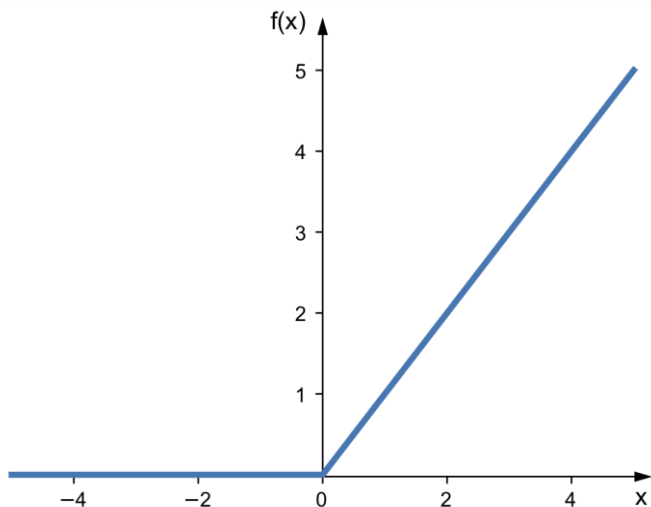


ReLU и GELU

ReLU

$$f(z) = \max(0, z)$$

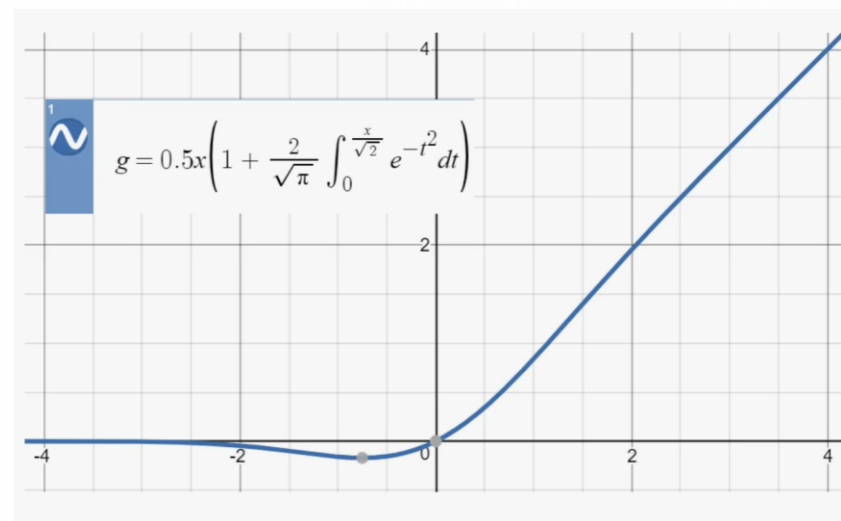
Кусочно-линейная, решает проблему затухающего градиента в положительной области. Вычислительно дешёвая. **Проблема:** «умирающие нейроны» (dead ReLU) при устойчиво отрицательном входе.



GELU

$$GELU(x) = xP(X \leq x) = x\Phi(x).$$

Гладкая, вероятностно мотивированная аппроксимация ReLU. Используется в трансформерных архитектурах (BERT, GPT) благодаря лучшим свойствам градиента около нуля.



Методическая связь: активации и атаки

- Природа функций активации определяет локальную «кривизну» решающей границы — концепция, к которой вернёмся в лекции 2 (резкие минимумы и чувствительность к возмущениям) и в лекции 4 (линейная гипотеза Fast Gradient Sign Method (FGSM) атаки).

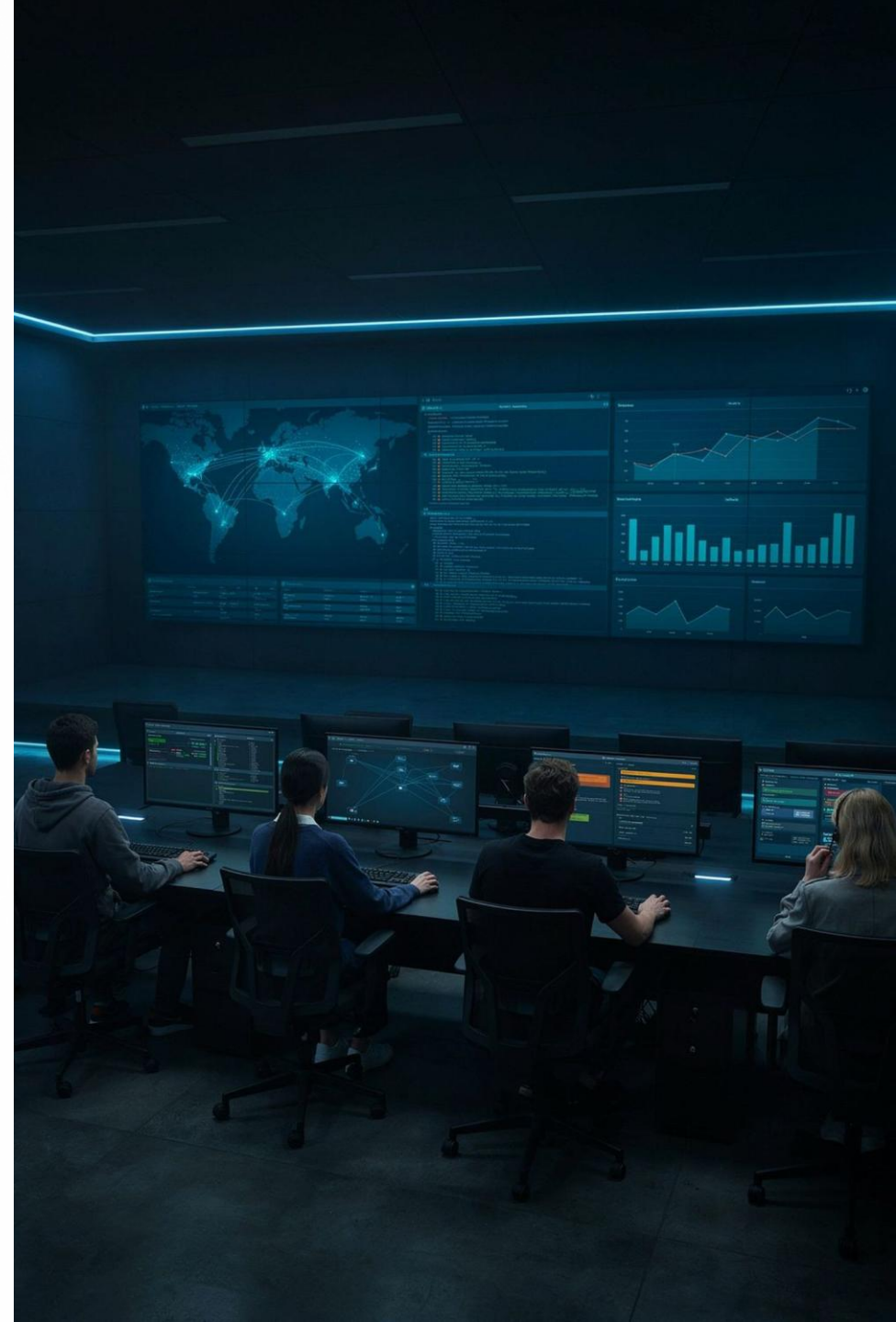
→ Кусочно-линейные (ReLU)

Определяют резкие изломы решающей границы — источник уязвимости к малым возмущениям.

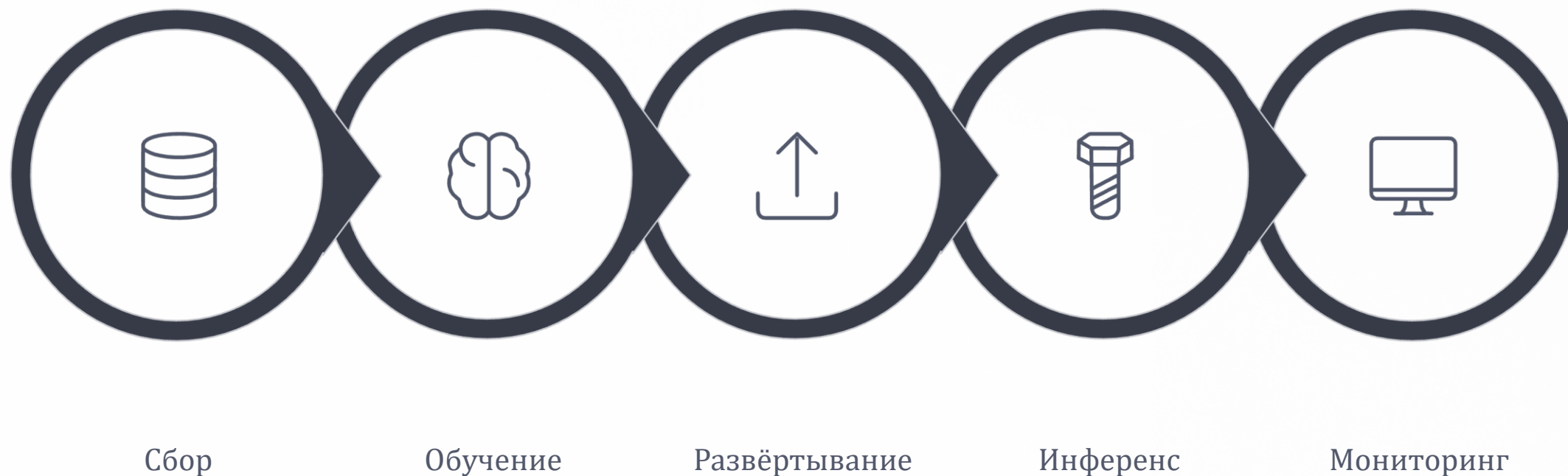
→ Насыщающиеся (sigmoid, tanh)

Создают гладкую, но «плоскую» границу в зонах насыщения, затрудняя обучение и влияя на устойчивость.

Жизненный цикл **ML**-системы и карта угроз



Пять этапов жизненного цикла



Ключевая идея: каждый этап образует собственную **поверхность атаки** со специфическим классом угроз, систематизированным в таксономии NIST AI 100-2.

NIST AI 100-2 — это комплексный фреймворк, определяющий атаки на состязательное машинное обучение, меры по смягчению последствий и терминологию как для предиктивных, так и для генеративных систем ИИ.



Этап 1: Сбор и подготовка данных

Класс атак

Poisoning-атаки: data poisoning, clean-label poisoning, backdoor poisoning.

Механизм

Внедрение вредоносных или скрыто триггерных примеров в обучающую выборку. Модель обучается на «отравленных» данных и приобретает нежелательное поведение.

Этап 2: Обучение (Training Stage)

Model Poisoning

Манипуляция параметрами модели или функцией потерь в процессе тренировки.

Атаки на федеративное обучение

Манипуляция обновлениями модели или градиентами от отдельных участников распределённого обучения.

Этап 3: Развёртывание (Deployment)

Supply Chain-атаки

Компрометация сторонних зависимостей, библиотек или инфраструктуры развёртывания.

Атаки через предобученные модели

Компрометация стороннего чекпоинта модели — атакующий внедряет бэкдор в публично доступные веса до их загрузки командой.

Этап 4: Эксплуатация (Inference)

Evasion-атаки

Целенаправленное возмущение входа для смены предсказания модели (adversarial examples).

Energy-Latency атаки

Специально сконструированные входы, истощающие вычислительные ресурсы инференса.



Этап 5: API-доступ и Privacy-атаки



Model Extraction

Восстановление структуры и параметров модели через серию запросов к API.



Membership Inference

Определение, входил ли конкретный объект в обучающую выборку.



Data Reconstruction

Восстановление обучающих данных из параметров или предсказаний модели.

Этап 6: Мониторинг

Адаптивные атаки

Атаки, специально построенные с учётом знания о механизме обнаружения — атакующий «обходит» детектор, зная его логику.

Эволюционирующие угрозы

Атаки, которые адаптируются к изменениям в системе мониторинга со временем, сохраняя эффективность при обновлении защит.

Сводная карта угроз по этапам

Этап	Класс атак	Пример механизма
Сбор данных	Data/backdoor poisoning	Вредоносные примеры в обучающей выборке
Обучение	Model poisoning, федеративные атаки	Манипуляция градиентами
Развёртывание	Supply chain-атаки	Компрометация чекпоинта
Инференс	Evasion, energy-latency	Возмущение входа для смены предсказания
API-доступ	Privacy-атаки	Extraction, membership inference
Мониторинг	Адаптивные атаки	Обход детекторов

NIST AI 100-2: Пять измерений риска



Редакция 2025 года добавляет новые категории: clean-label poisoning, indirect prompt injection для генеративных систем, misaligned outputs и energy-latency атаки — отражая рост значимости угроз для LLM и агентных ИИ-систем.



РАЗДЕЛ 4

Классификация угроз по целям атакующего: **СИА**-триада

CIA-триада в контексте ML

Классическая триада информационной безопасности — **Confidentiality, Integrity, Availability** — переносится на ML-системы с сохранением базовой логики, но с ML-специфичным содержанием каждого понятия.

Availability Доступность	Integrity Целостность	Confidentiality Конфиденциальность
------------------------------------	---------------------------------	--



Нарушение доступности (Availability)

Атакующий стремится сделать систему **неработоспособной** или существенно снизить общую точность модели. Типичные механизмы: массовое отравление обучающих данных (data poisoning) или energy-latency атаки, истощающие вычислительные ресурсы инференса.

Нарушение целостности (Integrity)

Суть атаки

Атакующий заставляет модель **систематически ошибаться в его интересах**, при этом модель формально продолжает «работать».

Примеры

- Evasion-атаки (adversarial examples)
- Backdoor-атаки с триггером
- Целевой (targeted) poisoning

Нарушение конфиденциальности (Confidentiality)



Data Reconstruction

Восстановление обучающих данных, которые должны оставаться скрытыми.



Membership Inference

Определение факта участия конкретного объекта в обучающей выборке.



Model Extraction

Извлечение модели как интеллектуальной собственности через запросы к API.

CIA-триада как концептуальный каркас безопасности

□ Любая новая атака, изучаемая в последующих лекциях, может быть классифицирована по тому, какую из трёх целей CIA она преследует — это облегчает построение формальной модели угроз в финальном проекте.



Модели угроз по объёму доступа атакующего



White-Box: Полный доступ

Что знает атакующий

- Архитектура модели
- Значения весов
- Градиенты
- Обучающие данные

Применение

Наиболее сильная модель угроз. Используется для построения **PGD** и **Carlini-Wagner атак** и для оценки «верхней границы» уязвимости модели.

FGSM - the fast gradient sign method

PGD - the projected gradient downward

CW method - the Carlini–Wagner method

Gray-Box: Частичное знание

Знает архитектуру, но не веса

Атакующий может строить суррогатные модели, но не имеет точных параметров цели.

Доступ к части данных

Атакующий имеет выборку из того же распределения, что и обучающие данные.

Тип модели без гиперпараметров

Знание класса модели (например, CNN) без точной конфигурации.

Black-Box: Только вход/выход

Атакующий не имеет доступа ни к архитектуре, ни к весам, ни к градиентам — только **query access** (взаимодействие через вход/выход). Наиболее релевантная модель для реальных production-систем, доступных через API.

Будем разбирать детально в лекции 6 через трансферируемость и запрос-ограниченные атаки.



Практическая значимость классификации доступа

- ❏ При построении реального security-аудита ML-системы первый шаг — определить, какой уровень доступа реалистично может получить потенциальный атакующий. Это прямо определяет, какие атаки стоит тестировать в рамках red-team.

1

Определить уровень доступа

White / Gray / Black-box

2

Выбрать релевантные атаки

PGD, FGSM, transfer, query-based

3

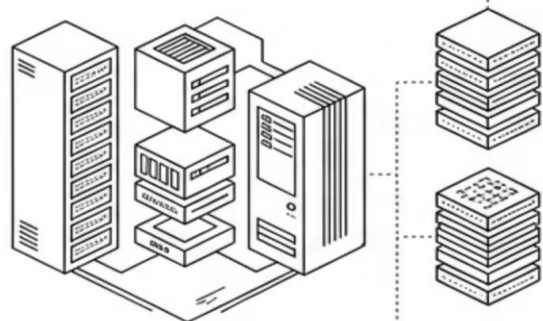
Провести **Red Team**

Сравнение моделей угроз

Белая-коробка

Полный доступ:

Архитектура



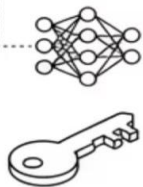
Архитектура

Весы

Градиенты

Обучающие данные

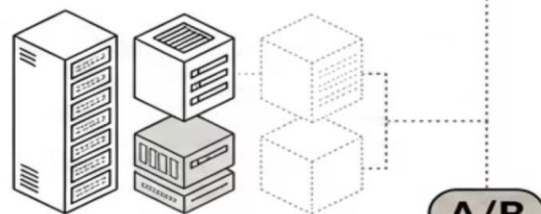
Сильнейшая угроза



Серая-коробка

Частичное знание:

Архитектура



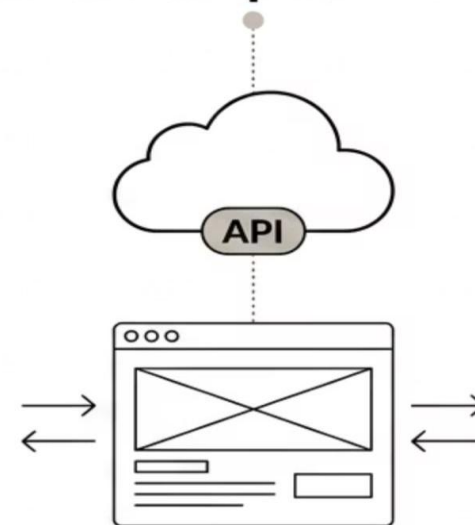
ИЛИ

Подмножество данных

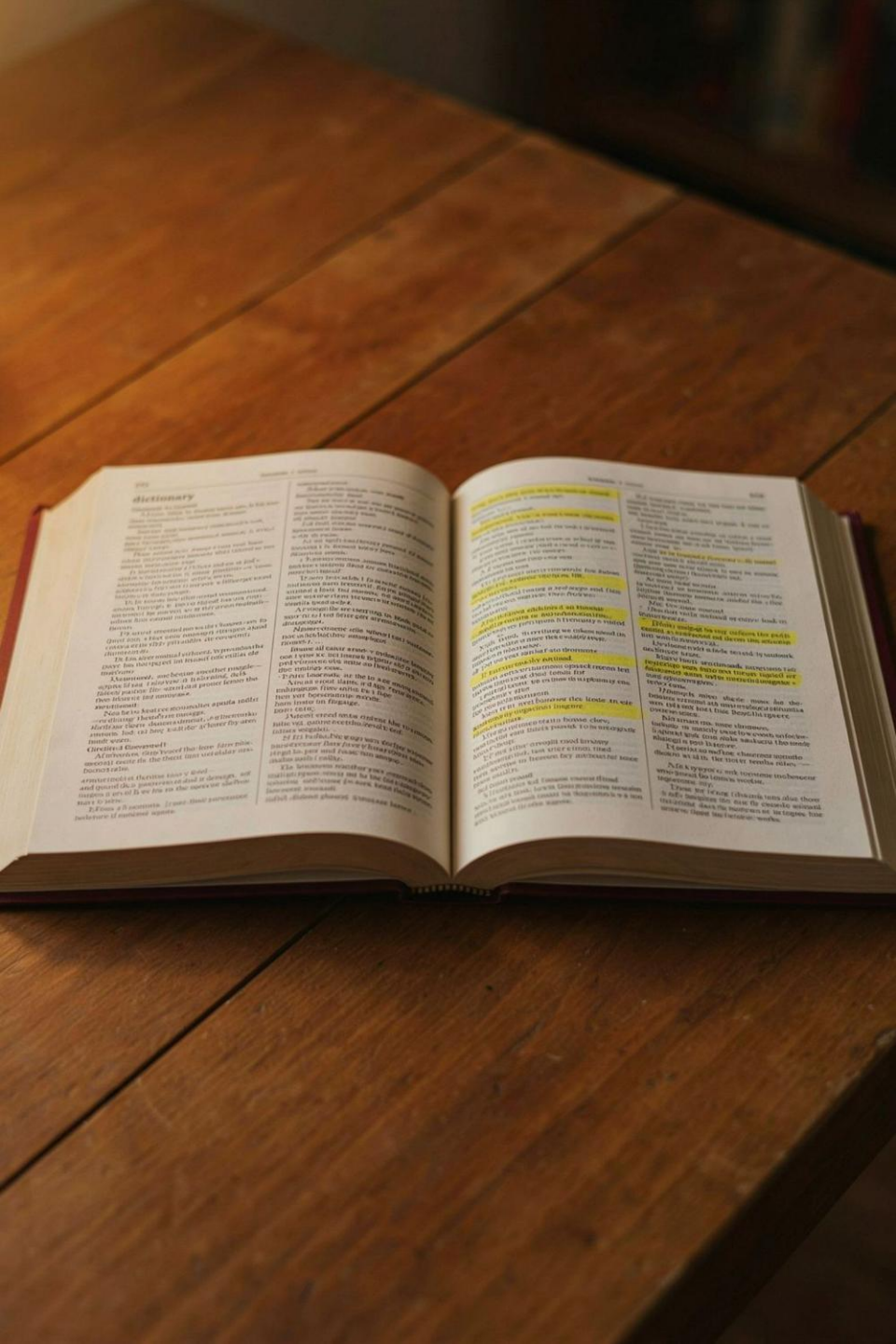
Подмножество данных

Черная-коробка

Только запросы к API:



Реалистично для продакшена



Ключевые термины

Adversarial Example

Adversarial Example

Модифицированный тестовый образец, **визуально или семантически близкий к оригиналу** по заданной метрике расстояния, но вызывающий неверное предсказание модели.

Согласно словарю NIST AI 100-2, это центральный объект изучения в adversarial ML.



Robustness (Устойчивость)

Robustness — способность модели сохранять корректное поведение при наличии возмущений входа, шума или атак в пределах заданного бюджета. Формально задаётся, например, через L_∞ шар радиуса ϵ вокруг исходного примера.

Attack Surface (Поверхность атаки)



Входные данные

Все точки подачи данных на вход модели при инференсе.



Обучающий пайплайн

Процесс сбора, разметки и предобработки данных.



API инференса

Интерфейс взаимодействия с моделью в production.



Сторонние компоненты

Зависимости и предобученные модели из внешних источников.

Threat Model (Модель угроз)

Формальное описание предполагаемого атакующего, используемое как основа для проектирования защит и оценки рисков.

Цели

Availability / Integrity / Privacy

Возможности

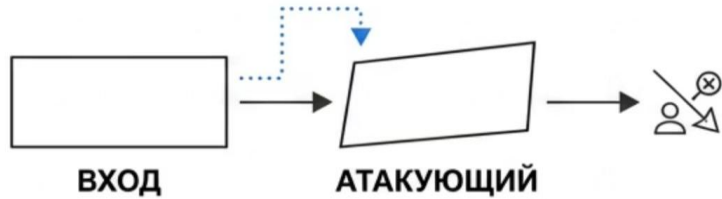
White / Gray / Black-box

Знания о системе

Архитектура, веса, данные, API

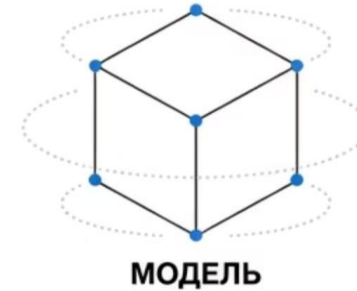
Четыре термина — минимальный словарь

Атакующий Пример



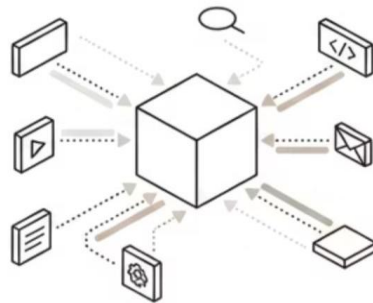
Входные данные, измененные для ошибки модели.

Устойчивость



Способность модели сохранять точность при атаках.

Поверхность Атаки



Все точки взаимодействия с системой.

Модель Угрозы



Описание целей, возможностей и знаний атакующего.

Связь терминов с таксономией NIST AI 100-2

Фундаментальное деление атак

- **Evasion** — атаки на инференс
- **Poisoning** — атаки на обучение
- **Privacy** — атаки на конфиденциальность

Фиксация в стандарте

Это деление зафиксировано в NIST AI 100-2 и является основой для систематизации всех атак, изучаемых в курсе. Каждый из введённых терминов напрямую соответствует элементам таксономии.

Evasion, Poisoning, Privacy: Три столпа таксономии

1

Evasion

Атаки на этапе инференса. Adversarial examples, energy-latency. Нарушение целостности.

2

Poisoning

Атаки на этапе обучения. Data poisoning, backdoor. Нарушение доступности и целостности.

3

Privacy

Атаки на конфиденциальность. Extraction, membership inference. Нарушение конфиденциальности.

Новые категории **NIST AI 100-2** (2025)

Clean-Label Poisoning

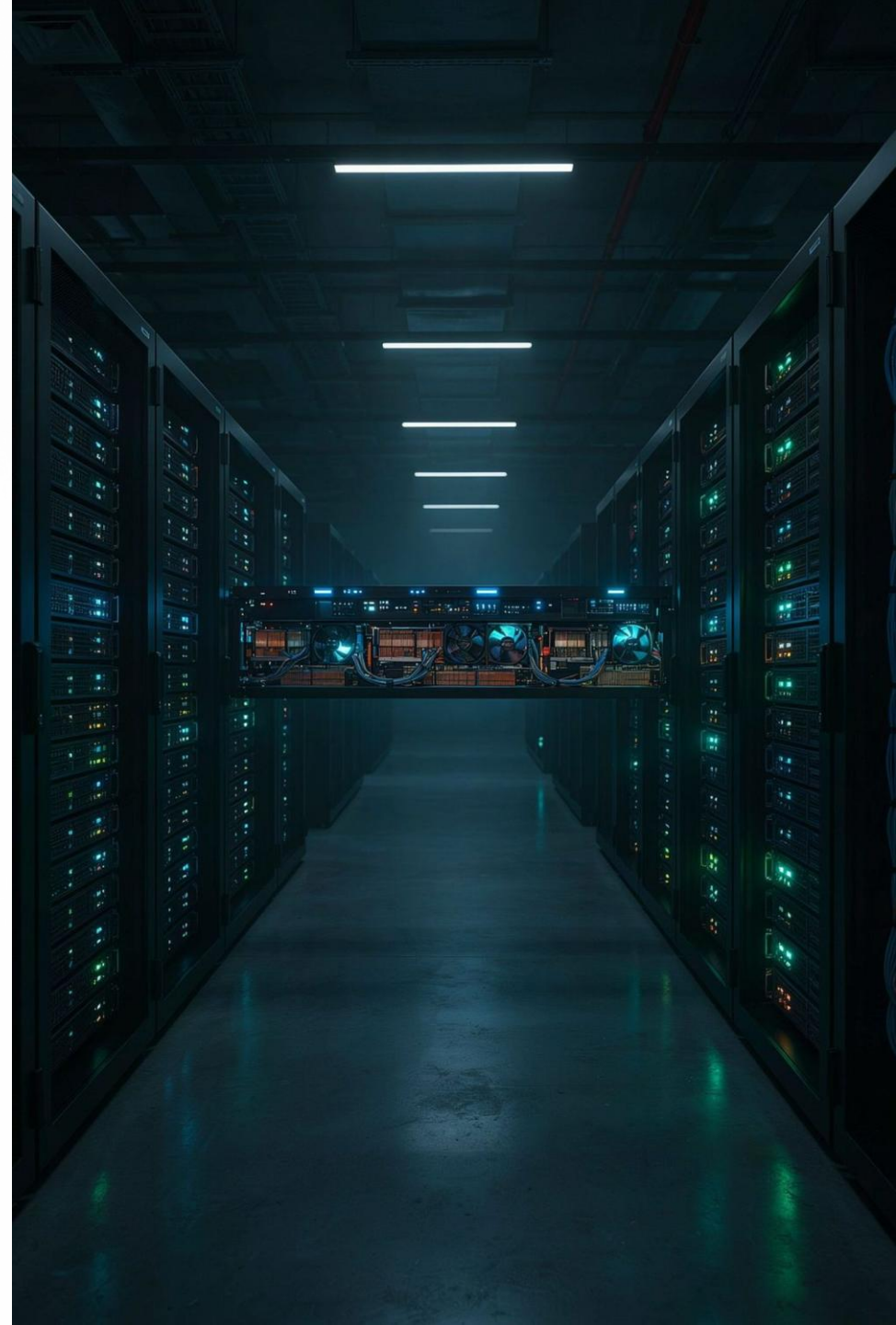
Отравление без изменения меток — атакующий вносит скрытые возмущения в данные, сохраняя корректные метки.

Indirect Prompt Injection

Атаки на генеративные системы через внешний контент, обрабатываемый LLM-агентом.

Misaligned Outputs & Energy-Latency

Новые категории, отражающие рост значимости атак на LLM и агентные ИИ-системы.



Финальный проект: Red Team / Blue Team

Red Team

Студенты строят атаки на ML-систему, опираясь на выбранную модель угроз (white/gray/black-box) и цели CIA-триады.

Blue Team

Студенты проектируют защиты и оценивают риски, используя формальную модель угроз и словарь курса.

Все концепции лекции 1 — attack surface, threat model, CIA-классификация, уровни доступа — напрямую применяются в финальном проекте.

От теории к практике: словарь в действии

Термин	Определение	Применение в финальном проекте
Adversarial example	Возмущённый вход, вызывающий ошибку	Объект атаки в Red Team
Robustness	Устойчивость к возмущениям в бюджете ϵ	Метрика оценки защиты
Attack surface	Все точки взаимодействия с системой	Область анализа угроз
Threat model	Формальное описание атакующего	Основа технического задания

Практический чеклист: построение Threat Model

1 Определить тип системы

Предсказательная или генеративная? Какова архитектура и область применения?

2 Определить уровень доступа атакующего

White, gray или black-box? Какие данные и компоненты доступны?

3 Классифицировать цели по CIA

Availability, integrity или confidentiality? Какой ущерб наиболее критичен?

4 Выбрать релевантные атаки

Evasion, poisoning или privacy? Какие механизмы реалистичны для данного контекста?

Таксономия NIST AI 100-2: структура документа

01	02
Тип ИИ-системы	Этап жизненного цикла
Предсказательная (классификация, регрессия) или генеративная (LLM, диффузионные модели).	Сбор данных, обучение, развёртывание, инференс, мониторинг.
03	04
Цели и возможности атакующего	Контрмеры
СИА-триада × уровень доступа (white/gray/black-box).	Защиты, соответствующие каждому классу атак и уровню доступа.

Резюме: архитектурные основы

Перцептрон → MLP

Добавление скрытых слоёв и нелинейных активаций преодолевает ограничение линейной разделимости.

Функции активации

Sigmoid, tanh, ReLU, GELU — каждая определяет форму решающей границы и характер уязвимостей.

Универсальная аппроксимация

Мощность MLP — и источник их силы, и источник сложности их защиты.

Резюме: карта угроз

Жизненный цикл → **Attack Surface**

Каждый из пяти этапов (сбор, обучение, развёртывание, инференс, мониторинг) имеет свой класс атак.

CIA-триада в ML

Availability (poisoning), Integrity (evasion, backdoor), Confidentiality (extraction, inference).

White / Gray / Black-box

Уровень доступа атакующего определяет выбор атак и стратегию red-team аудита.

Источники и стандарты

NIST AI 100-2 (2024/2025)

Vassilev et al. «Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations». Основной стандарт курса. Редакция 2025 года расширяет таксономию новыми категориями для LLM и агентных систем.

CIA Triad

Классическая триада информационной безопасности, адаптированная для ML-контекста. Основа классификации целей атакующего.

Minsky & Papert (1969)

Формальное доказательство ограничений однослойного перцептрона (теорема XOR) — исторический контекст развития глубокого обучения.

Итог лекции

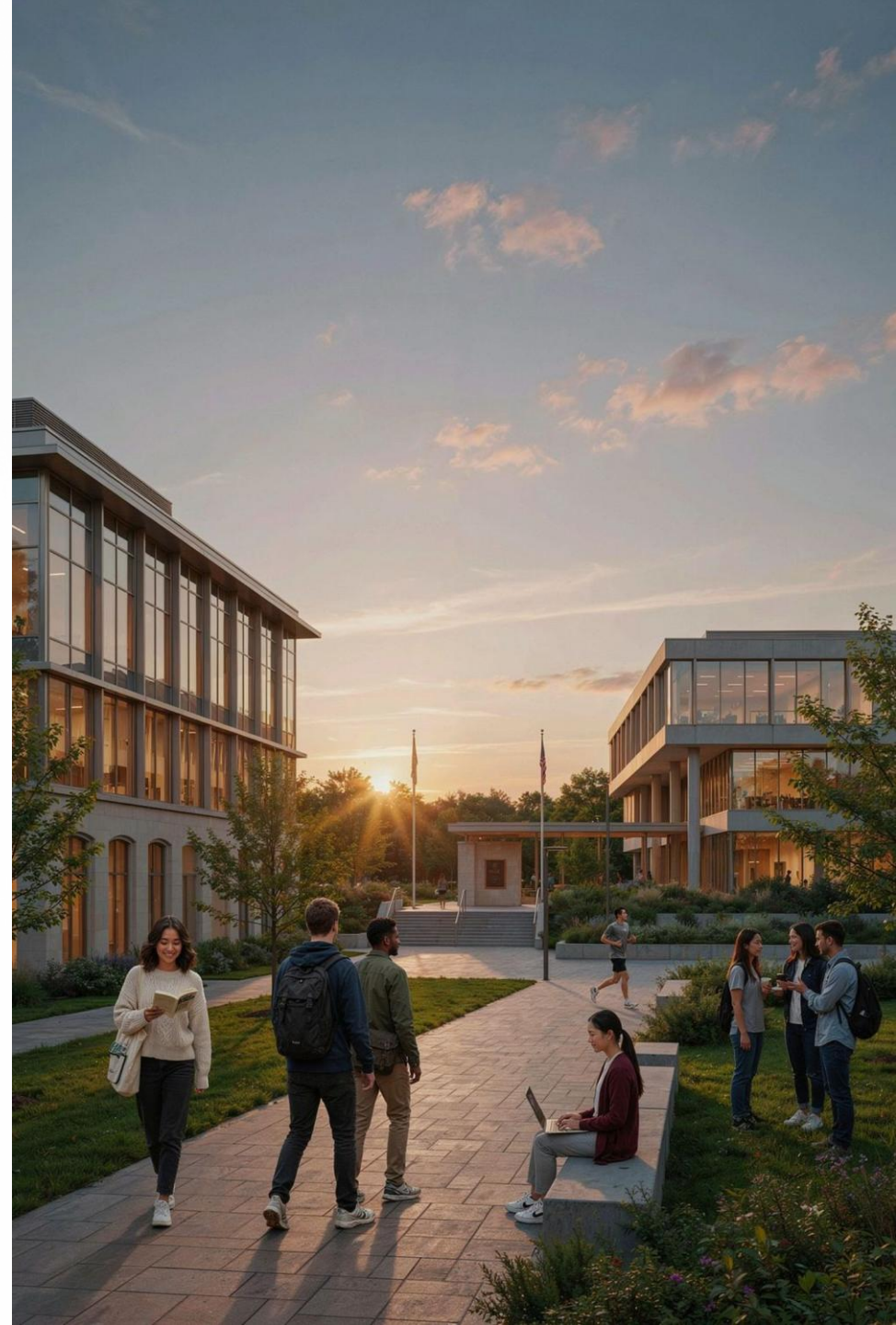
Безопасность ИИ-систем — сквозное измерение, а не опциональная надстройка. Понимание архитектурных основ глубокого обучения неотделимо от понимания поверхности атаки, которую эти архитектуры создают.

Следующая лекция

Резкие минимумы, геометрия решающей границы и их связь с чувствительностью к возмущениям.

Подготовка

Прочитать NIST AI 100-2, разделы 1–3. Ознакомиться с понятием ϵ -ball в контексте robustness.



Связь лекции 1 с последующими темами курса

